

THE ENTERPRISE PR REVIEW PLAYBOOK

Volume I — Traditional Review Discipline

How Pull Requests Actually Flow Through Elite Engineering Organizations —
Workflow, Ownership, Role-Based Review Playbooks, Anti-Patterns, and
Metrics

A practitioner-level reference synthesized from published engineering practices at Google, Meta, Microsoft, Netflix, Amazon, Uber, Airbnb, Stripe, Shopify, LinkedIn, Datadog, and Cloudflare, plus DORA/SPACE research and open-source tooling documentation.

Series: 5 Volumes · Volume 1 of 5
July 2026

Contents

How to Use This Series

Section 1 — How PR Review Works in Elite Engineering Organizations

- 1.1 The canonical pipeline: developer to production
- 1.2 Ownership models and CODEOWNERS
- 1.3 Company-by-company review culture
- 1.4 Merge queues, stacked PRs, and trunk-based development
- 1.5 Monorepo vs. polyrepo review dynamics

Section 2 — Role-Based Review Playbooks

- 2.1 Junior Developer
- 2.2 Senior Developer
- 2.3 Staff Engineer
- 2.4 Principal Engineer / Distinguished Engineer
- 2.5 Enterprise Architect
- 2.6 Security Architect
- 2.7 Platform Engineer
- 2.8 Site Reliability Engineer (SRE)
- 2.9 QA Engineer
- 2.10 Data Engineer
- 2.11 AI Engineer
- 2.12 AI Architect

Section 12 — Review Anti-Patterns Catalog

Section 13 — PR Metrics: DORA, SPACE, and Review Health

About This Series

How to Use This Series

This is Volume 1 of a five-part reference on how pull requests are actually reviewed inside high-performing engineering organizations, covering both the traditional human review discipline and — in later volumes — the emerging discipline of AI-assisted and agentic review.

Volume 1 focuses on **mechanics and human judgment**: how PRs physically move through an organization, what each reviewing role is actually looking for, the failure modes that recur across companies regardless of tooling, and the metrics organizations use to know whether review is working. It is written for engineers who already know how to open a pull request and want to understand the judgment layer that sits on top of the mechanics — the difference between a reviewer who checks syntax and one who protects a system's future.

Companion volumes in this series:

- **Volume 2** — Deep domain reviews: architecture/ADR/RFC discipline, security review, infrastructure-as-code, database migrations, API contracts, documentation review.
- **Volume 3** — AI-assisted review today: Copilot, Claude Code, Cursor, CodeRabbit, Greptile, Graphite, Amazon Q — capabilities, failure modes, and where human oversight remains non-negotiable.
- **Volume 4** — Agentic AI review architecture: multi-agent reviewer design, MCP/A2A orchestration, policy engines, and governance for autonomous review pipelines.
- **Volume 5** — Case studies, master checklists, scorecards, and a review maturity model.

A note on sourcing: claims about specific companies are drawn from published engineering blogs, the *Software Engineering at Google* book, conference talks, and vendor documentation where available, and are marked as such. Where a practice is common but not tied to a single public source, it is presented as general industry practice rather than attributed to a specific company.

Section 1 — How PR Review Works in Elite Engineering Organizations

1.1 The Canonical Pipeline

Beneath the surface differences in tooling, nearly every mature engineering organization runs pull requests through the same conceptual pipeline. What differs is which stages are automated, which are mandatory, and how much human judgment is layered on top of each gate.

- **Author self-review** — the developer re-reads their own diff before requesting review; at Google this is supported by presubmit checks run inside the review tool itself before a human ever sees the change.
- **Continuous Integration** — build, unit tests, linting, type-checking; a change that fails CI is not eligible for human review time in almost every serious organization.
- **Static analysis / SAST** — automated analyzers annotate the diff directly; Google's internal analyzer ecosystem (historically Tricorder) surfaces findings inline in the review tool, and reviewers can mark a finding "please fix" or "not useful" to tune the signal over time.
- **Security scanning** — secrets detection, dependency/SCA scanning, and for sensitive paths, a human security reviewer.
- **Architecture / design conformance** — for changes that touch a system boundary, a check against an existing ADR/RFC or a request for one to be written.
- **Owner review** — the human decision point: does someone with context and authority over this code agree the change should exist in this form?
- **Merge** — via direct merge, merge queue, or stacked-PR cascade depending on org maturity.
- **Deployment** — progressive rollout (canary, staged, feature-flagged) rather than a single big-bang release.
- **Post-deployment validation** — SLO dashboards, automated rollback triggers, and in the best organizations, an explicit "bake time" before a change is considered safe.

The single biggest structural difference between elite and average organizations is not the presence of these stages — most companies have all of them on paper — it is how much is enforced by tooling versus left to reviewer discipline, and how fast the loop runs. Google's internal data, reported in *Software Engineering at Google*, put the median time for a change to receive its first review at roughly four hours, with small changes reviewed within about an hour and larger ones within about five — fast enough that review is not experienced as a queueing system.

1.2 Ownership Models and CODEOWNERS

Two philosophies dominate how organizations decide who is allowed to approve a change.

Explicit path-based ownership (CODEOWNERS)

GitHub, GitLab, and most polyrepo shops use a CODEOWNERS file mapping directory globs to teams or individuals. A PR touching `/payments/**` automatically requests review from the payments team and, depending on branch protection settings, cannot merge without their sign-off. This scales well in polyrepo or modular-monorepo setups but tends to fragment as an organization grows — stale CODEOWNERS files listing

people who have left the team are one of the most common sources of review latency in mid-size companies.

Certification-based ownership (Google's readability model)

Google's model, described extensively in its public engineering practices documentation, decouples "do you own this directory" from "are you qualified to approve this language's style and idiom." Every changelist requires approval from someone with **readability certification** in the language being changed — a credential earned through a structured review-of-reviews process, obtained once per language and then held for the engineer's tenure. Combined with an ownership requirement for the specific code area, this is why Google can run on a single-approver norm at enormous scale: the certification substitutes for having many senior people re-litigate style on every review.

Most organizations outside Google use a hybrid: CODEOWNERS for domain authority, plus informal or semi-formal recognition ("senior engineer," "tech lead") for judgment authority, without a structured certification process.

1.3 Company-by-Company Review Culture

Representative Review Cultures

Review Question	Why It Matters
Google	Single-approver norm (ownership + readability). Reviews run through Critique, Google's internal tool, with inline static-analysis findings, an "attention set" mechanism showing whose turn it is to act, and a stated cultural goal of same-day turnaround.
Meta	Heavy internal tooling (Phabricator historically, now largely internal successors) with stacked-diff workflows as the default rather than the exception — Meta's Sapling source control system was built specifically to make stacked, iterative review the natural way of working.
Microsoft	More heterogeneous than Google's monoculture; a mix of tool-driven review and over-the-shoulder / pairing-style review is explicitly sanctioned, reflecting Microsoft's more federated engineering culture across product groups.
Netflix, Stripe, Shopify, Airbnb, Uber, LinkedIn, Datadog, Cloudflare	Broadly converge on GitHub/GitLab-based review with required CODEOWNERS approval, CI gating, and increasing adoption of merge queues; these companies are also the primary commercial adopters and case studies behind stacked-PR tooling such as Graphite, reflecting a shared pain point of large-PR review latency in fast-growing product organizations.

*Sourced from public engineering blogs, the *Software Engineering at Google* book, and vendor case-study material; treat company-specific claims as illustrative of broad practice rather than a verbatim account of any single team's current process, which evolves continuously.*

1.4 Merge Queues, Stacked PRs, and Trunk-Based Development

As PR volume grows, two related but distinct problems emerge: (1) large, long-lived branches produce painful, low-quality reviews, and (2) even well-reviewed PRs collide with each other at merge time, producing "semantic" conflicts that pass CI individually but break trunk in combination.

Trunk-based development

The practice of merging small, frequent changes directly into a shared trunk (often behind feature flags for anything incomplete) rather than maintaining long-lived feature branches. It is the precondition for everything else in this subsection — a team cannot productively adopt merge queues or stacking without first being comfortable with short-lived branches and rapid integration.

Stacked pull requests

Rather than one large PR, an engineer decomposes a feature into a sequence of small, dependent PRs, each branched from the previous one. Each layer is independently reviewable and mergeable; a reviewer can approve the bottom of the stack while the top is still being iterated on. Tools purpose-built for this — Graphite, Meta's Sapling, and lighter-weight open-source tools like ghstack and stack-pr — automate the tedious part: when an early PR in the stack changes, every dependent PR above it must be rebased, and doing this by hand is where manual stacking breaks down. Graphite's own guidance to teams adopting stacking recommends keeping PRs under roughly 200 lines and targeting sub-24-hour review turnaround as the concrete standards that make the workflow pay off.

Merge queues

A merge queue serializes the final integration step: PRs approved for merge enter a queue, are rebased onto the latest trunk, re-validated by CI, and merged in order — preventing the situation where two individually-safe PRs combine into a broken trunk. Stack-aware merge queues (Graphite's is the most prominent example) go further, validating and fast-forwarding an entire approved stack together rather than serializing every layer through CI individually, which matters once a team is merging dozens of stacked PRs a day.

1.5 Monorepo vs. Polyrepo Review Dynamics

Monorepo vs. Polyrepo — What Changes for the Reviewer

Review Question	Why It Matters
Blast radius visibility	Monorepo reviewers can see every downstream consumer of a changed interface in the same review; polyrepo reviewers often cannot see consumers at all without cross-repo tooling or a service catalog.
Ownership enforcement	Monorepos need path-based CODEOWNERS at massive scale (Google's is famous for this); polyrepos get ownership "for free" from repo boundaries but lose cross-cutting visibility.
CI cost and selectivity	Monorepo CI must be smart about only building/testing affected targets (Bazel-style dependency graphs); polyrepo CI is naturally scoped but duplicated across repos.
Cross-cutting refactors	Trivial in a monorepo (one PR touches everything); in polyrepo, a breaking API change requires coordinated, sequenced PRs across many repos and often a deprecation period enforced by contract testing.

Section 2 — Role-Based Review Playbooks

The same diff produces a different review depending on who is reading it. A junior developer and a principal engineer looking at the identical PR are running different mental models — not because one is more careful, but because they are optimizing for different failure modes. This section documents, role by role, what an experienced person in that seat is actually looking for, what they deliberately let go, and what they say when something is wrong.

2.1 Junior Developer

What they review	Correctness of the immediate change; does the code do what the description says; obvious null/boundary bugs; whether tests exist and pass; adherence to visible style conventions.
What they deliberately ignore	Whether this is the right architectural approach at all; long-term maintainability; whether this duplicates logic that exists elsewhere in a part of the codebase they haven't seen.
Questions they ask	"Does this match the ticket?" "Did I break any existing tests?" "Is there an example elsewhere in the codebase I should follow?"
Approval criteria	Tests pass, the diff matches the stated intent, and a more senior reviewer has also looked at it — junior review is rarely the last gate on anything consequential.
Common comments	"Nit: variable name could be clearer." "Should this have a test for the empty-list case?" "I don't understand what this line does — can you add a comment?"
Anti-patterns they flag	Rubber-stamping because the CI is green; reviewing only the lines that changed and never opening the surrounding file for context.

2.2 Senior Developer

What they review	Correctness plus local design: is this the right abstraction for this file/module; error handling completeness; test coverage of edge cases and failure paths; whether the change respects existing module boundaries.
What they deliberately ignore	Broader system architecture debates that belong in a design doc, not a PR comment; micro-style issues already caught by linters.
Questions they ask	"What happens when this call fails?" "Is this concurrency-safe?" "Why this approach instead of [alternative]?" "Does this need a migration plan for existing data?"
Approval criteria	The change is correct, tested, and consistent with the module's existing patterns; any deviation from convention is deliberate and justified in the PR description, not accidental.
Common comments	"This will race under concurrent access — see line X." "Can we extract this into a shared utility instead of duplicating it?" "This needs a test for the timeout case."
Anti-patterns they flag	Approving because "it looks like the surrounding code" without checking whether the surrounding code is itself a known problem; nitpicking style while missing a logic error.

2.3 Staff Engineer

What they review	Cross-team and cross-service impact; whether the change introduces coupling that will be expensive to unwind later; consistency with architectural direction the org has committed to; whether the change is the right size (should this be split, or does it belong in a bigger redesign).
What they deliberately ignore	Line-by-line style; test naming conventions; anything already enforced by CI.
Questions they ask	"Who else consumes this interface, and did they get a heads-up?" "Does this quietly become load-bearing infrastructure that nobody signed up to own?" "Is there a simpler way to get 80% of the value?"
Approval criteria	The change is technically sound <i>and</i> organizationally sound — it doesn't create a surprise dependency, doesn't silently expand another team's on-call surface, and is proportionate to the problem.
Common comments	"This creates a hard dependency from team A to team B's internal data model — can we go through the public API instead?" "This PR is doing three unrelated things; can we split it?"
Anti-patterns they flag	Blocking a reasonable PR to relitigate an architecture decision that was already made in an ADR; over-engineering a simple change because of hypothetical future scale.

2.4 Principal / Distinguished Engineer

What they review	Strategic fit: does this move the system toward or away from where the organization is trying to go; second-order consequences (what does this make easier or harder to do next); whether this is solving the real problem or a symptom; organizational risk (does this quietly become a single point of failure or a key-person dependency).
What they deliberately ignore	Implementation detail that a competent staff engineer has already covered; anything that is purely a matter of team preference.
Questions they ask	"What does this foreclose?" "If this succeeds, what do we build next on top of it, and does this design support that?" "Is this the right layer for this decision, or are we solving an organizational problem with a technical one?"
Approval criteria	The change is defensible not just today but as a precedent — other teams will point to this PR as "how we do X here." Principal-level approval is often about setting a pattern, not just clearing a diff.
Common comments	"This is fine as a one-off, but if we're about to do this five more times, we should build the shared primitive now." "This needs an ADR before it merges, not after."
Anti-patterns they flag	Reviewing everything at this level of scrutiny, which does not scale and signals a breakdown of trust in staff/senior review; being the bottleneck on changes that don't need this altitude of review.

2.5 Enterprise Architect

What they review	Alignment with enterprise reference architecture and business-capability model; whether the change respects bounded-context and domain boundaries (in the DDD sense); future extensibility against the multi-year roadmap; compliance with published enterprise standards; ADR traceability.
What they deliberately ignore	Implementation-level code quality — that is delegated to engineering review.
Questions they ask	"Does this belong to the domain that owns it, or is it leaking a capability across a bounded context?" "Is there an existing enterprise pattern for this, and if not, should one be created?" "Does this align to an approved ADR, and if not, why not?"
Approval criteria	The change fits the target-state architecture, or there is an explicit, time-boxed exception recorded (with an owner and a remediation plan) if it doesn't.
Common comments	"This duplicates a capability that already exists in the Customer domain — can we reuse it instead of building a parallel model?" "This needs to go through the architecture review board before merge."
Anti-patterns they flag	Architecture review as a rubber-stamp committee with no teeth; enterprise standards so rigid they get routinely bypassed, which erodes the review's legitimacy entirely.

2.6 Security Architect

What they review	AuthN/AuthZ correctness; OWASP Top 10 classes (injection, SSRF, XSS, CSRF, broken access control); secrets and credential handling; encryption in transit and at rest; PII handling and data classification; RBAC/ABAC model correctness; multi-tenancy isolation; trust-boundary crossings; supply-chain risk (dependency provenance, SBOM, signed artifacts).
What they deliberately ignore	Business logic correctness unrelated to a security control; UI/UX decisions.
Questions they ask	"What is the trust boundary here, and does this change cross it?" "If this input is attacker-controlled, what happens?" "Is this secret ever logged, cached, or returned in an error message?" "Does this new dependency introduce a supply-chain risk we haven't accepted before?"
Approval criteria	No new class of vulnerability is introduced; any new trust boundary is explicitly modeled and least-privilege is preserved; secrets never appear in code, logs, or version control.
Common comments	"This endpoint is missing an authorization check — anyone with a valid session, not just the resource owner, can call this." "This dependency was published two days ago with no history — hold until it has more provenance."
Anti-patterns they flag	Security review that happens only at the end, after architecture is locked in, forcing an expensive rework; treating every finding as blocking regardless of actual exploitability, which trains engineers to route around security review entirely.

2.7 Platform Engineer

What they review	Deployment safety (containers, Helm charts, Kubernetes manifests, Terraform); resource requests/limits; backward compatibility of infra changes; feature-flag hygiene; observability wiring (is this new service emitting metrics/logs/traces by default); golden-path conformance.
What they deliberately ignore	Application-level business logic — platform review is about the substrate the code runs on, not what the code does.
Questions they ask	"Does this have resource limits, or will it starve its neighbors?" "Is this rollback-safe if the deploy needs to be reverted mid-rollout?" "Does this follow the golden path, or is it a bespoke deployment pattern we'll have to support forever?"
Approval criteria	The change deploys safely, is observable by default, and doesn't introduce a one-off infrastructure pattern that platform engineering will be asked to maintain indefinitely.
Common comments	"This Helm chart has no resource limits set — that's how one bad deploy takes down the node." "Can this use the shared logging sidecar instead of a custom log shipper?"
Anti-patterns they flag	Approving infra changes without checking rollback behavior; allowing bespoke, unsupported deployment patterns to proliferate because saying no is friction in the moment.

2.8 Site Reliability Engineer (SRE)

What they review	SLI/SLO impact; timeout and retry configuration; idempotency of operations that may be retried; rate limiting and backpressure; circuit-breaker presence on external calls; rollback plan; chaos/failure-mode readiness; whether the change is safe to deploy during business hours.
What they deliberately ignore	Code style; whether the abstraction is elegant, so long as it's operationally safe.
Questions they ask	"What happens when this dependency is slow or down?" "Is this operation idempotent if the client retries?" "What's the blast radius if this is wrong, and how fast can we roll it back?" "Does this add load to a system that's already near its SLO budget?"
Approval criteria	The change has a bounded, understood failure mode; retries are capped and jittered; rollback is fast and tested, not theoretical.
Common comments	"This external call has no timeout — a hung dependency will hang every caller." "This retry loop has no backoff and will hammer the downstream service during an incident."
Anti-patterns they flag	No rollback plan ("we'll just fix forward"); retries without backoff or jitter, which turn a minor blip into a self-inflicted DDoS ("retry storm"); deploying a risky change on a Friday afternoon with nobody available to respond.

2.9 QA Engineer

What they review	Testability of the change; presence and quality of integration tests, not just unit tests; regression risk against existing behavior; edge cases the author didn't consider; contract-test coverage for consumer-facing interfaces.
What they deliberately ignore	Internal implementation detail that has no externally observable behavior.
Questions they ask	"How would I test this if I had to do it manually?" "What's the smallest input that breaks this?" "Does this change any documented contract, and if so, is there a contract test for it?"
Approval criteria	The change is verifiable — there's a way to know, mechanically, whether it's working — and the tests actually exercise the failure paths, not just the happy path.
Common comments	"This only tests the success case — what does the API return on a malformed request?" "This will regress the behavior tested in [existing test], which now needs updating or is silently broken."
Anti-patterns they flag	Tests that assert on implementation detail rather than behavior, which break on every refactor and get deleted rather than fixed; non-deterministic ("flaky") tests tolerated because "that test is always flaky," which erodes trust in the entire suite.

2.10 Data Engineer

What they review	Schema evolution safety (additive vs. breaking); data-contract compliance for downstream consumers; lineage impact; backfill strategy for historical data; partitioning and volume implications.
What they deliberately ignore	Application-layer business logic that doesn't touch the data model.
Questions they ask	"Is this schema change backward-compatible for consumers still on the old contract?" "Does this need a backfill, and if so, what's the plan and the cost?" "Does this break anything downstream in the lineage graph?"
Approval criteria	The schema change is additive or has an explicit, communicated deprecation window; backfill (if needed) is planned and sized, not left as a surprise for whoever runs the migration.
Common comments	"This renames a column that three downstream pipelines depend on — this needs a dual-write period, not a hard cutover." "What's the expected row count for this backfill, and has anyone estimated the runtime?"
Anti-patterns they flag	Breaking schema changes shipped without notifying consumers; backfills run against production without a dry run or a rollback plan; silently changing the meaning of an existing field instead of adding a new one.

2.11 AI Engineer

What they review	Prompt quality and versioning; guardrail and content-filter coverage; model routing logic (cost/latency/capability tradeoffs); temperature and sampling parameter appropriateness for the task; structured-output schema enforcement; hallucination and grounding risk; evaluation coverage for the specific change; RAG retrieval quality; conversational memory handling; token cost per request at expected volume; latency budget.
What they deliberately ignore	Whether the underlying model architecture is state-of-the-art — that's a model-selection decision, not a PR-level one.
Questions they ask	"What happens when the model returns something outside the expected schema?" "Is there an eval suite that would have caught a regression in this prompt change?" "What's the cost per request at expected traffic, and does that scale linearly with a bad actor sending long inputs?" "Is user data that shouldn't be retained ending up in a memory store?"
Approval criteria	The change has eval coverage showing it doesn't regress quality on the existing benchmark set; structured outputs are validated against a schema rather than trusted as-is; failure modes (malformed output, refusal, timeout) are handled explicitly.
Common comments	"This prompt change wasn't run against the eval suite — we don't know if it regresses the existing golden set." "There's no fallback if the model returns invalid JSON here." "This will blow the latency budget for the synchronous request path — should this be async?"
Anti-patterns they flag	Shipping a prompt tweak with no eval run ("it looked better on three examples"); trusting raw model output without schema validation; unbounded conversation memory that grows context and cost without limit; no fallback behavior when the model call fails or times out.

2.12 AI Architect

What they review	Agent and tool-orchestration design; memory strategy (what persists, what doesn't, and why); evaluation framework coverage at the system level, not just the prompt level; human-approval checkpoints for consequential actions; multi-agent communication protocol and failure isolation; context-engineering discipline (what enters the context window and why); prompt/version governance across the whole agent, not one prompt.
What they deliberately ignore	Individual prompt wording, which is delegated to the AI engineer role.
Questions they ask	"What happens if this agent gets into a loop — is there a hard iteration cap?" "Which actions require human approval before execution, and is that enforced in code, not just documented?" "If one agent in a multi-agent system produces a bad output, does it poison the others, or is there isolation?" "How is context window growth bounded over a long-running session?"
Approval criteria	The system has bounded failure modes: agents cannot loop indefinitely, cannot take irreversible consequential actions without an explicit approval gate, and degrade gracefully rather than cascading failure across a multi-agent pipeline.
Common comments	"This tool call has no rate limit and no maximum-iteration cap — an agent stuck in a retry loop could rack up unbounded cost or take unbounded action." "This action (deleting data, sending money, emailing a customer) needs a human-in-the-loop gate, not just a confidence threshold."
Anti-patterns they flag	Infinite agent loops with no hard iteration ceiling; context explosion from unbounded memory or tool-output accumulation, driving both cost and quality degradation; consequential actions (financial, destructive, externally visible) gated only by a soft confidence score rather than a hard human checkpoint; silent memory leakage of one user's context into another's session.

Section 12 — Review Anti-Patterns Catalog

These patterns recur across companies, tech stacks, and review tools. They are grouped by where in the pipeline they tend to originate.

12.1 Process Anti-Patterns

- **LGTM without review** — approval given because the reviewer trusts the author, not because they read the diff; erodes the entire signal value of "approved."
- **Giant PRs** — changes too large to hold in working memory get either rubber-stamped or reviewed so slowly that the author has moved on to unrelated work by the time comments arrive.
- **Missing ADR** — an architecturally significant decision made silently inside a PR, with no record of the alternatives considered or why this one won, leaving future engineers to reverse-engineer intent from a diff.
- **No rollback plan** — "we'll fix forward" as a strategy, discovered to be inadequate only during an actual incident.
- **Hidden breaking changes** — a change that is technically backward-compatible in the code but breaks an implicit contract (timing, ordering, error format) that consumers depend on.
- **Architecture drift** — many individually-reasonable PRs that, in aggregate, move the system away from its documented target architecture with nobody noticing until a much larger remediation is required.

12.2 Code-Level Anti-Patterns

- **Business logic duplication** — reimplementing a rule that already exists elsewhere, creating two sources of truth that will inevitably drift.
- **Magic constants** — unexplained numeric or string literals that encode a business rule with no record of why that value was chosen.
- **Over-engineering** — building for a scale or flexibility requirement that doesn't exist yet, at the cost of present-day readability.
- **Premature optimization** — complexity introduced for a performance problem that hasn't been measured or demonstrated.
- **Non-deterministic tests** — flaky tests tolerated rather than fixed or deleted, which teaches the team to ignore CI failures generally.

12.3 AI-Era Anti-Patterns

- **Prompt copied from a chat session** — a prompt that worked in an interactive session, shipped into a production system without adaptation for adversarial input, cost at scale, or failure handling.
- **Hardcoded secrets in AI configuration** — API keys embedded directly in prompt templates or agent configuration files rather than a secrets manager.
- **Prompt injection surface left open** — user-controlled text concatenated directly into a system prompt or tool-calling context with no delimiting or sanitization.
- **Unsafe tool grants** — an agent given a tool with broader permissions than the task requires "in case it's useful later."
- **Infinite agent loops** — no hard cap on iterations, tool calls, or cost for an autonomous agent loop.

- **Context explosion** — unbounded accumulation of tool output or conversation history into the context window, degrading both quality and cost predictably over a long session.
- **Token waste** — redundant context re-sent on every call instead of cached or summarized.
- **Memory leakage** — one user's or session's context appearing in another's due to a shared or improperly scoped memory store.
- **Silent failures** — an agent or model call that fails and is swallowed rather than surfaced, producing a confidently wrong result with no error signal.

Section 13 — PR Metrics: DORA, SPACE, and Review Health

13.1 DORA Metrics

The DORA (DevOps Research and Assessment) program, now part of Google Cloud, established four metrics that correlate with high-performing engineering organizations. PR review discipline is a primary lever on two of the four:

DORA Metrics and Their Relationship to Review

Review Question	Why It Matters
Deployment frequency	How often an organization successfully releases to production. Small, frequently-reviewed PRs are a direct enabler; large infrequent PRs are a direct inhibitor.
Lead time for changes	Time from code committed to code running in production. Review latency is typically the single largest component of lead time in organizations that have already automated build and deploy.
Change failure rate	Percentage of deployments causing a failure in production. This is where review depth (not just speed) matters — a review culture optimized purely for throughput tends to raise this metric even as it improves the first two.
Time to restore service	How long it takes to recover from a production failure. Influenced by review discipline around rollback plans and observability wiring, not by review speed.

13.2 SPACE Framework

Where DORA measures delivery outcomes, the SPACE framework (from Microsoft Research, GitHub, and academic collaborators) is designed to capture developer productivity more holistically, explicitly warning against optimizing on any single dimension — including review-specific ones — in isolation.

- **Satisfaction and well-being** — do engineers find the review process fair and useful, or a source of dread and delay.
- **Performance** — outcome-based, not activity-based; a PR merged fast that causes an incident is not high performance.
- **Activity** — volume of PRs, commits, reviews completed; useful as a leading indicator, dangerous as a target in itself (Goodhart's Law applies directly to "number of reviews done").
- **Communication and collaboration** — quality of review discussion, cross-team review participation, knowledge transfer happening through comments.
- **Efficiency and flow** — how much a developer's work is interrupted by context-switching while waiting on review, which stacked-PR and merge-queue tooling directly targets.

13.3 Review-Specific Metrics

Operational Review Metrics

Review Question	Why It Matters
Review latency (time to first review)	The clock from PR-opened to first human comment. Google's internal norm is measured in hours, not days; organizations with multi-day review latency should treat it as a top-tier engineering-productivity problem, not a personnel issue.
Time to merge	PR-opened to merged. Distinct from review latency — a PR can get fast first feedback and still take days to merge through review-comment cycles.
Review depth / comment density	Comments per line changed, tracked as a trend rather than an absolute target; a sudden drop across an org is a leading indicator of LGTM-without-review culture.
Defect escape rate	Bugs found in production that should have been caught in review, typically traced back via incident postmortems to a specific PR and reviewer chain.
Post-deployment incident rate	Incidents per N deployments, segmented by PR size and review depth where possible — this is the metric that closes the loop on whether review is actually working, as opposed to merely happening.
PR size distribution	Median and p90 lines changed per PR; a rising p90 over time is an early warning that trunk-based/small-PR discipline is eroding.

A caution on all of the above: every metric in this section degrades once it becomes a target used to evaluate individual engineers rather than a signal used to improve the system. Review latency measured to reward the fastest approver produces LGTM-without-review; comment density used to reward "thorough" reviewers produces nitpicking on trivial PRs while missing real issues. Treat these as organizational health indicators, reviewed in aggregate and in trend, not as individual performance targets.

About This Series

This volume is part of a five-part Enterprise PR Review Playbook. Volume 2 covers deep domain review — architecture, security, infrastructure, database, API, and documentation review in practitioner-level detail. Volumes 3 and 4 cover AI-assisted and agentic review architectures. Volume 5 collects case studies, master checklists, and a review maturity model for enterprise adoption.

Generated as a synthesized practitioner reference. Company-specific claims are drawn from public engineering blogs, official documentation, and published research current as of mid-2026; internal practices at any given company evolve continuously and specific tooling names may change.